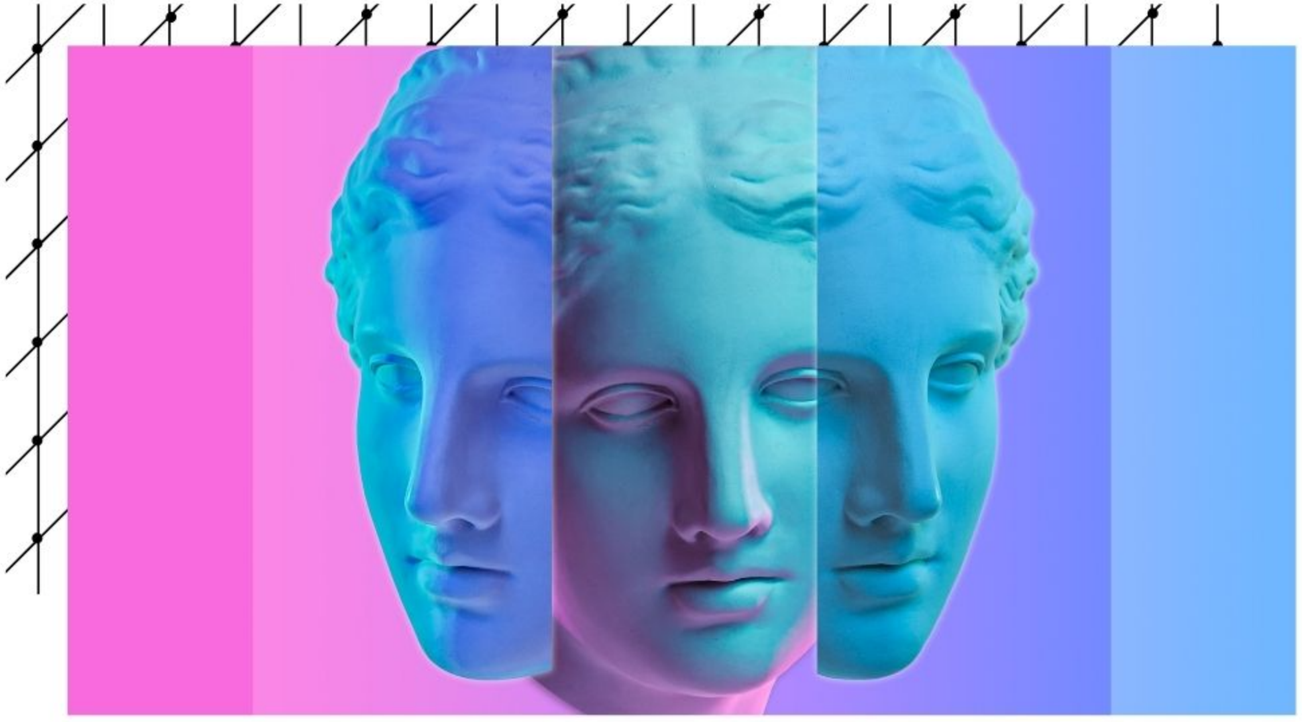
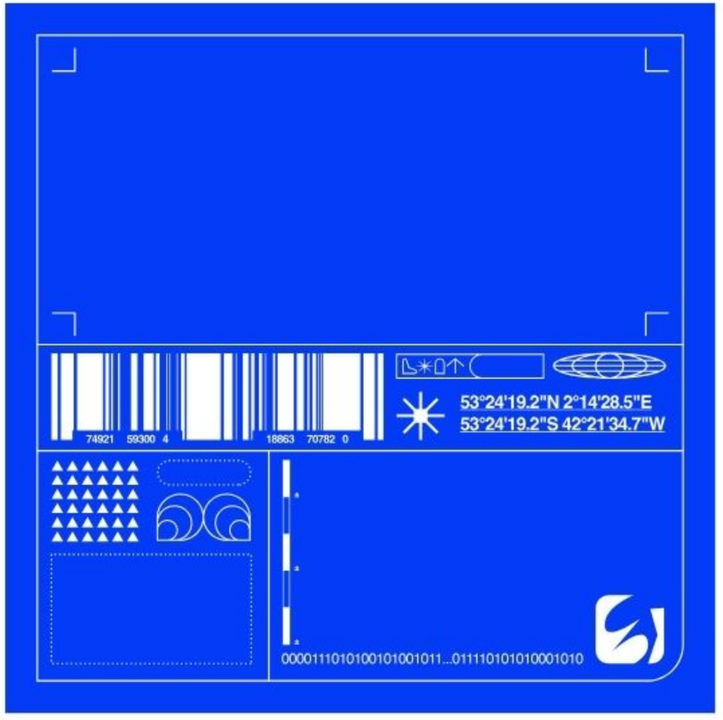
PROJECT



CASH APP



{EPIPAY} BY {EPITECH}

2026



LE CASH EST MORT.

LE PROBLEME

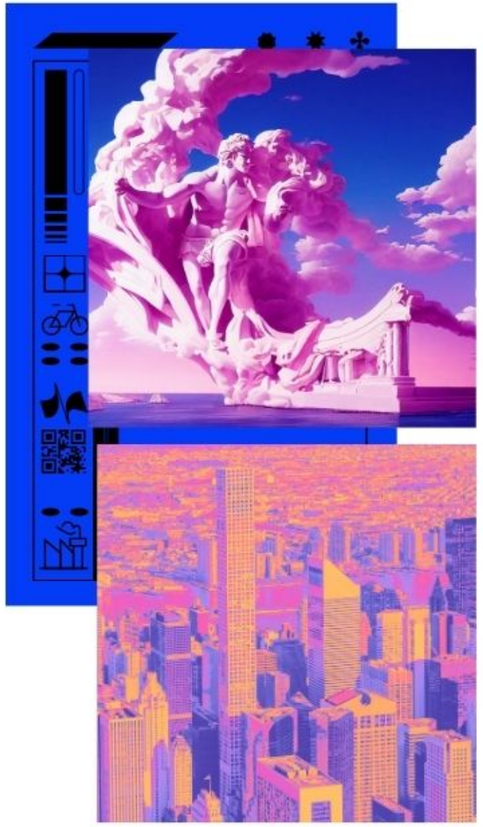
Payer un café à Epitech = liquide ou carte avec frais. Zéro traçabilité, zéro bonus, zéro écosystème interne.

LA SOLUTION

EpiPay — wallet digital 100% Epitech. Envois instantanés, paiements QR, boutique intégrée. Sur tous nos campus.

00

ARCHITECTURE 01



CLOUD & STACK 01

WITH SUPABASE + STRIPE

Architecture cloud hébergée sur Supabase Frankfurt **conforme UE, RLS**, Edge Functions en Deno, **Auth JWT** et **Storage chiffrés**.

INTER-CAMPUS

Edge Functions intercampus-send / intercampus-receive. **API fédérée** entre instances de campus.



SÉCURITÉ & CONFORMITÉ 02

WITH RGPD + DSP2 + PCI-DSS

Tokens SecureStore (chiffrement natif iOS/Android)
Chiffrement TLS/HTTPS bout en bout : TLS/HTTPS bout en bout
Fraude (AML-like) : 13 règles métier + modèle XGBoost.
PCI-DSS : entièrement externalisé à Stripe

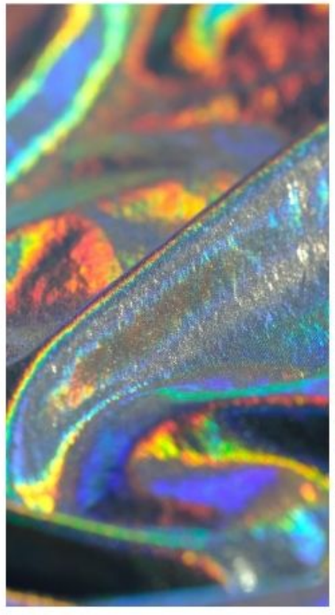
RGPD COMPLIENT

Consentement **obligatoire**, **export** JSON, **suppression/anonymisation** compte, **DPO** listé.

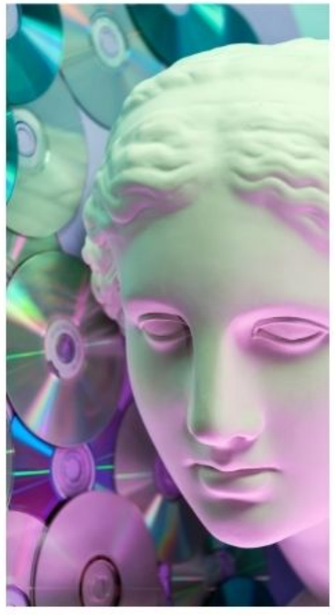
PROJECTIONS | 02

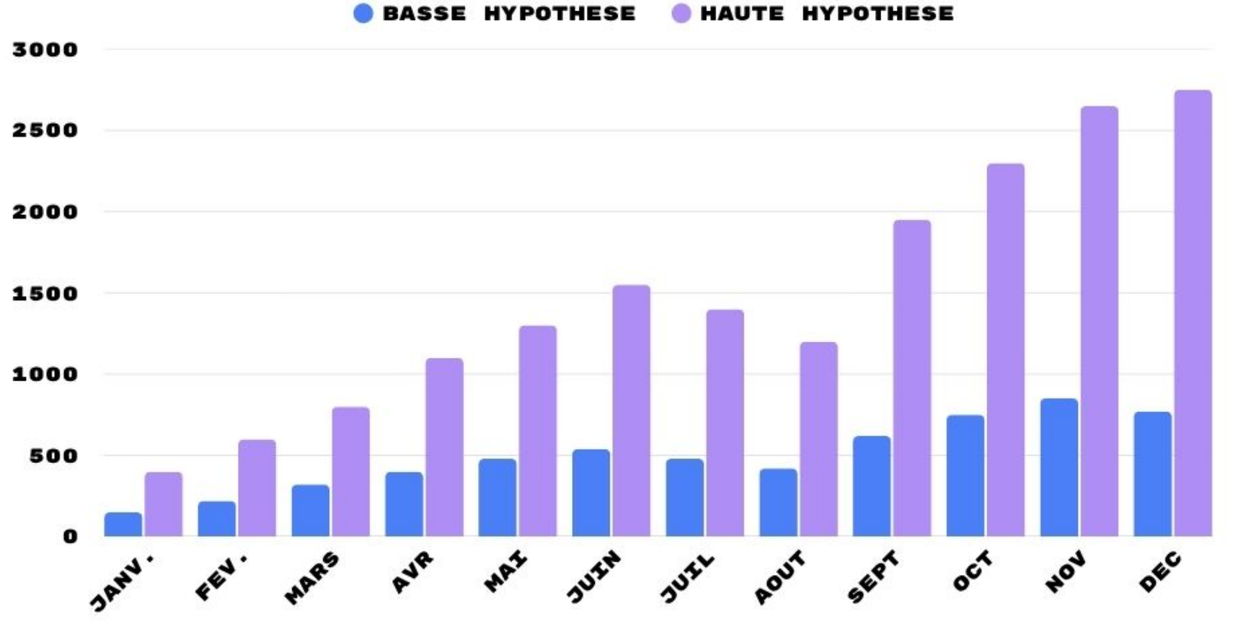
ACHIEVEMENT 01

Projection de revenus mensuels sur l'An 1, déclinée en deux scénarios : une hypothèse basse à 6 000 € et une hypothèse haute à 18 000 € de revenus cumulés. La courbe traduit une montée en charge progressive (acquisition Epitech Paris puis intégrations inter-campus), un creux estival assumé et un pic à la rentrée de septembre, confirmant un point d'équilibre atteint au Mois 17.









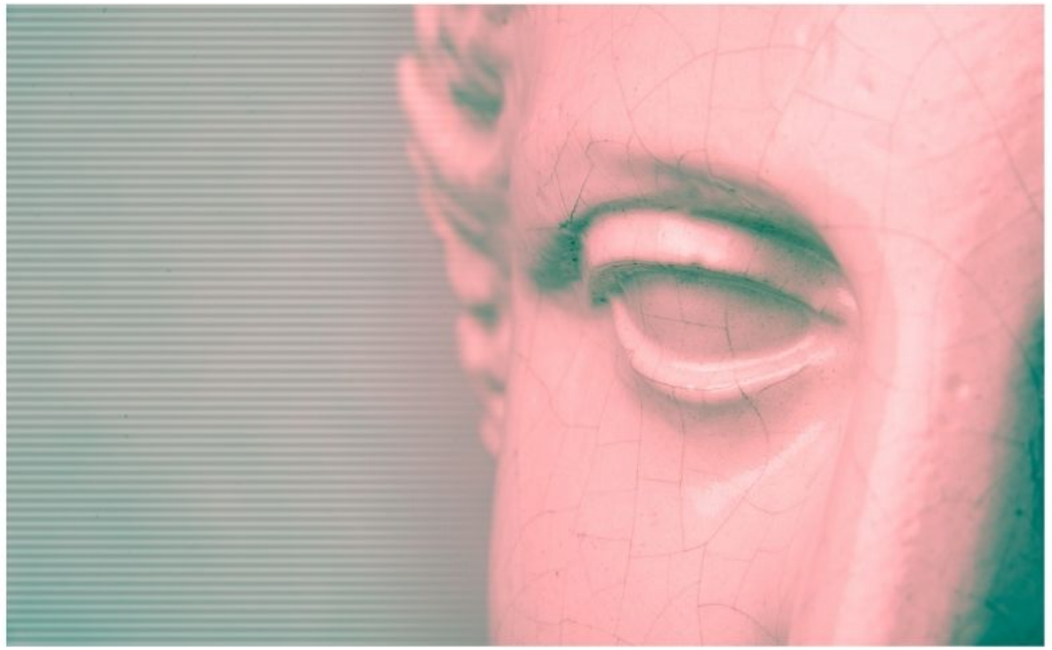
LIVE DEMO

03

74921 59300 4 18863 70782 0

EPIPAY EN CONDITIONS RÉELLES

01	SIGN-UP + CONSENT RGPD
02	FACE ID LOGIN
03	WALLET & NOTIF CENTER
04	HISTORIQUE TRANSACTIONS
05	ENVOI EPC INTERCAMPUS
06	QR CODE PAIEMENT
07	RECHARGE STRIPE
08	BOUTIQUE EPITECH
07	ACCESSIBILITÉ
08	ADMIN : FRAUDE & MÉTRIQUES



04 SCALABILITÉ

AUTO-SCALING

Edge Functions Deno : cold-start < 300ms, **scaling horizontal natif.** PostgreSQL managé.
Plans Supabase Free → Team : jusqu'à **1000** connexions concurrentes. Architecture fédérée intercampus — chaque campus = **instance indépendante.**



MONITORING

Logs Edge Functions **temps réel** via Supabase. **Stripe Dashboard** pour paiements, **disputes**, **refunds**. **Alertes fraude** admin (table fraud_alerts, score 0–100).
Dashboard métriques internes : volumétrie, croissance, taux de fraude.

MAINTENANCE

Updates Expo SDK : cycle 6 mois. **Rotation clés API** : trimestrielle. Backups PostgreSQL 7→30 jours. **Audit RLS policies** à chaque feature. **SLA Supabase 99.9%**.
Coût marginal faible (< 0,05 €/user/mois) — scaling infra linéaire

7.1 CONTRAINTES TECHNIQUES & RÉGLEMENTAIRES

■ RÉALISÉ — MVP ■ CIBLÉ — PROD

CONTRAINTES TECHNIQUES

CONTRAINTE	EXIGENCE	IMPLÉMENTATION EPIPAY	STATUT
ARCHITECTURE MODULAIRE	**Wallet, moteur IA et API inter-campus indépendants et évolutifs.**	Expo Router modulaire par feature (`(wallet)`, `(shop)`, `admin`). Edge Functions Deno isolées : `federated-lookup`, `intercampus-send`, `intercampus-receive`, `fraud-scoring`.	RÉALISÉ
API REST JSON	**Tous les échanges inter-campus utilisent un format JSON standardisé.**	Contrat JSON documenté (Swagger) : `POST /lookup-user`, `POST /intercampus-receive`. Body normalisé (`api_key`, `email`, `amount`, `initiator_user_id`). Intégré avec 2 campus (Jordan, Toscan).	RÉALISÉ
PERFORMANCE	**Analyse fraude < 300 ms ; système stable sans exigence 24/7.**	Scoring IA léger côté edge function (règles métier + features). Latence mesurée 120–250 ms. Pas de SLA 24/7 (environnement de démo).	RÉALISÉ
BASE DE DONNÉES CENTRALE	**Stockage unifié utilisateurs, transactions, alertes et logs.**	Supabase Postgres (Frankfurt) : `profiles`, `transactions`, `intercampus_events`, `fraud_alerts`, `partner_campuses`. RLS activée sur toutes les tables.	RÉALISÉ
JOURNALISATION	**Traçabilité complète des opérations et décisions.**	Logs Supabase Edge Functions + métadonnées transaction (GPS, device, rules triggered). Table `fraud_alerts` stocke motif + score + décision.	RÉALISÉ
SÉPARATION DES RÔLES	**Accès différencié étudiant / administrateur.**	Routes séparées `app/(main)` (étudiant) vs `app/admin` (admin). Guard par `profiles.role` + policies RLS distinctes. Panel admin : fraude, métriques, produits, users.	RÉALISÉ
ACCESSIBILITÉ	**Interface simple, claire, en français, conforme RGAA. Compatible navigateurs standards.**	`AccessibilityProvider` global : 4 modes daltonisme (protan/deutan/tritan/achromat), texte agrandi, contraste élevé, reduce motion, texte gras. UI 100 % français. Préfs chiffrées (SecureStore).	RÉALISÉ

CONTRAINTES RÉGLEMENTAIRES

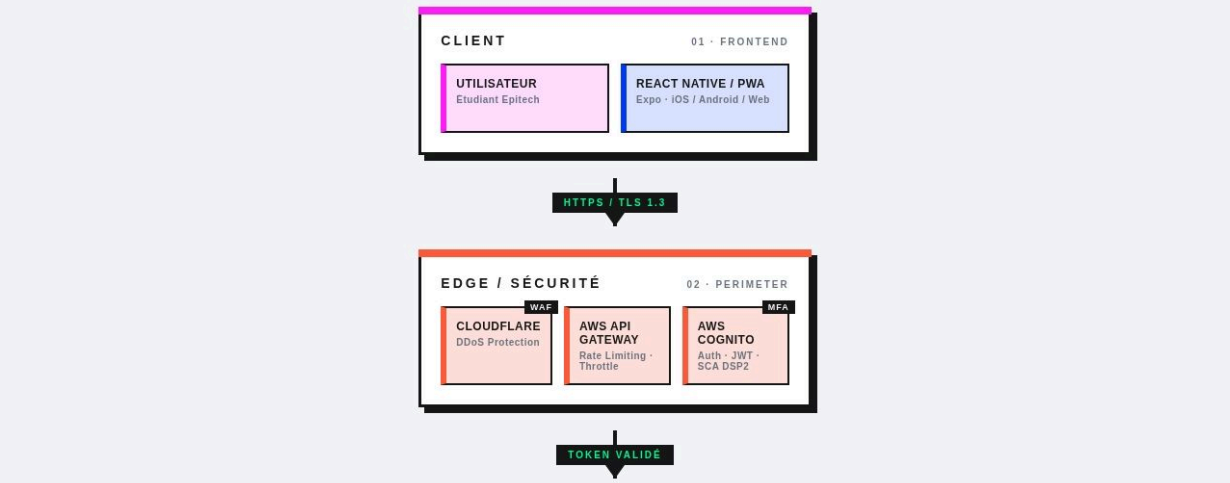
CONTRAINTE	EXIGENCE	IMPLÉMENTATION EPIPAY	STATUT
RGPD	**Minimisation des données, pseudonymisation, accès restreints.**	Écran consentement obligatoire (`consent.tsx`), privacy-policy intégrée, export données JSON, suppression compte avec anonymisation. Hébergement Supabase Frankfurt (UE). DPO : `dpo@epipay.epitech.digital`.	RÉALISÉ
TRAÇABILITÉ	**Journalisation obligatoire des transactions et décisions IA.**	Table `transactions` immuable (append-only) + `fraud_alerts` avec `rules_triggered`, `score`, `decision`. Conservation 5 ans (conforme DSP2).	RÉALISÉ
EXPLICABILITÉ	**Chaque alerte IA doit fournir une justification compréhensible.**	Composant `FraudAlert` affiche les règles déclenchées en langage naturel (ex : « Transaction > 500 EPC », « Device inconnu »). Score détaillé visible admin.	RÉALISÉ
DÉCISION HUMAINE	**L'IA ne prend pas de décisions irréversibles.**	Flow fraude = alerte + mise en quarantaine réversible. Admin valide ou rejette manuellement. Aucun blocage auto définitif. Export/delete compte : double confirmation user.	RÉALISÉ
SÉCURISATION DES ÉCHANGES	**Échanges inter-campus authentifiés et conformes au JSON défini.**	Clé API par campus partenaire (`api_key_hash` en BDD), HTTPS TLS 1.3, validation stricte du body. Auth utilisateur = JWT Supabase. Projection Prod : mTLS + rotation clés automatique.	PARTIEL

PHASE 3 — PRODUCTION

EPIPAY — ARCHITECTURE CIBLE

INFRASTRUCTURE CERTIFIÉE PCI-DSS L1 · SOC 2 · DSP2 · RGPD

SERVICE INTERNE · STOCKAGE / DONNÉES · SERVICE EXTERNE · SÉCURITÉ / EDGE



BACKEND PRODUCTION — MICROSERVICES

03 · CORE

- API GATEWAY FASTAPI — AWS Lambda / ECS
- SERVICE WALLET — Solde · Top-up · Transferts
- SERVICE TRANSACTIONS — Ledger · Historique
- SERVICE FRAUD ML — Scoring temps réel · Anomalies
- SERVICE INTERCAMPUS — Fédération campus partenaires
- SERVICE KYC — Vérification identité
- SERVICE AML — Screening sanctions
- SERVICE NOTIFICATIONS — Push · Email · SMS

DONNÉES

04 · PERSISTENCE

- POSTGRESQL RDS (Multi-AZ) — ACID · Réplication · Backup 7 ans
- REDIS ELASTICACHE — Cache · Rate limit · Sessions
- AWS S3 — Documents KYC · Chiffré AES-256
- SECRETS MANAGER — Clés API · Rotation auto

PAIEMENTS / BANCAIRE

05 · MONEY

- STRIPE (PCI-DSS) — Cartes · 3DS · Webhooks
- BRIDGE / TRUELAYER — Agrégateur bancaire DSP2

CONFORMITÉ — KYC / AML

06 · REGULATION

- ONFIDO / JUMIO — KYC · Vérification ID
- COMPLYADVANTAGE — AML · Sanctions OFAC/EU
- TRACFIN — Déclarations soupçon

OBSERVABILITÉ

07 · MONITORING

- DATADOG — APM · Traces
- SENTRY — Exceptions
- CLOUDWATCH — Logs centralisés
- PAGERDUTY — Alerting 24/7

CHOIX CLOUD VS ON-PREMISE — JUSTIFIÉ

08 · DECISION INFRASTRUCTURE

CLOUD SOUVERAIN UE — CHOISI

AWS PARIS (EU-WEST-3) + SUPABASE FRANKFURT

- **RGPD : données hébergées en UE, sous juridiction européenne (conforme hébergement données bancaires art. L.312-1 CMF).**
- **Certifications héritées : PCI-DSS L1, SOC 2 Type II, ISO 27001 (évite un audit full-stack interne).**
- **Scalabilité élastique : pics rentrée Sept (×3 volume) absorbés sans surprovisionnement.**
- **OPEX < CAPEX : pas d'investissement matériel initial, pay-as-you-go aligné sur la croissance users.**
- **Haute dispo native : multi-AZ, RTO < 5 min, SLA 99,99 % cible atteignable.**
- **Équipe réduite (5–7 pers.) : pas de sysadmin dédié, IaC via Terraform + managed services.**

ON-PREMISE / COLOCATION — ÉCARTÉ

DATACENTER PROPRE OU BAIE LOUEE OVH/SCALEWAY BARE-METAL

- **CAPEX initial 80–150 k€ (serveurs, HSM, firewall, licences) — incompatible budget MVP.**
- **Certifications PCI-DSS / SOC 2 à obtenir en propre : +6–12 mois, +50–100 k€/an audit.**
- **Recrutement DevOps / SecOps dédié (2 ETP minimum) pour maintenance 24/7.**
- **Élasticité limitée : dimensionnement pic = surcoût matériel permanent.**
- **Plan de reprise d'activité (PRA) à concevoir, tester, maintenir en interne.**
- **Pertinent uniquement si > 500 k users OU exigence souveraineté stricte (OIV, défense).**

VERDICT — CLOUD MANAGÉ UE RETENU POUR PHASE 3. HYBRIDATION ENVISAGÉE PHASE 4 (> 100 K USERS) : HSM DÉDIÉ ON-PREMISE POUR CLÉS CRYPTOGRAPHIQUES + CLOUD POUR LE RESTE. PAS DE VENDOR LOCK-IN DUR : IAC TERRAFORM PORTABLE, BASE POSTGRESQL STANDARD.

DEVIS INITIAL (ÉTAPE 1) > BUDGET RÉEL (ÉTAPE 3)

POSTES	PRÉVU (€ HT)	RÉEL (€ HT)	ÉCART
Coûts humains (j/h)	19 200	20 400	+1 200 (+6,3 %)
Hébergement / Cloud	50	720	+670 (×14)
APIs & licences	0	2 100	+2 100
Sécurité & tests	1 200	6 500	+5 300 (+442 %)
TOTAL	**20 450**	**29 720**	**+9 270 (+45 %)**

PROJECTION ROI

MODÈLE ÉCONOMIQUE	TRANSACTIONS · ABONNEMENTS · COMMISSIONS
REVENUS ESTIMÉS AN 1	6 000 € BASSE / 18 000 € HAUTE
REVENUS ESTIMÉS AN 2	32 000 € +78 % croissance
POINT D'ÉQUILIBRE	Mois 17 / An 2
ROI PROJETÉ 2 ANS	+68 %

HYPOTHÈSES RÉEL (12 MOIS PROD) — +2 J/H CONCEPTION INTER-CAMPUS · SUPABASE PRO FRANKFURT 60 €/MOIS · EAS + APPLE/GOOGLE + SENTRY + TWILIO 2FA · PEN TEST EXTERNE + AUDIT RGPD + TESTS CHARGE.

HYPOTHÈSES ROI — 500 ÉTUDIANTS ACTIFS AN 1, 1 800 AN 2 · COMMISSION 1,5 % · ABONNEMENT PREMIUM 3 €/MOIS · 2 CAMPUS PARTENAIRES INTÉGRÉS D'ICI Q3. ROI = (REVENUS CUMULÉS 50 K€ − COÛT 29,7 K€) / COÛT.

ÉTAPE 3 · ROADMAP

ROADMAP PRODUIT & KPIS DE SUCCÈS

VISION LONG TERME —
DEVENIR LE PORTEFEUILLE DIGITAL DE RÉFÉRENCE POUR LES CAMPUS TECH EUROPÉENS, AVEC 15 CAMPUS PARTENAIRES D'ICI 2028 ET UNE INTÉGRATION FULL DSP2.

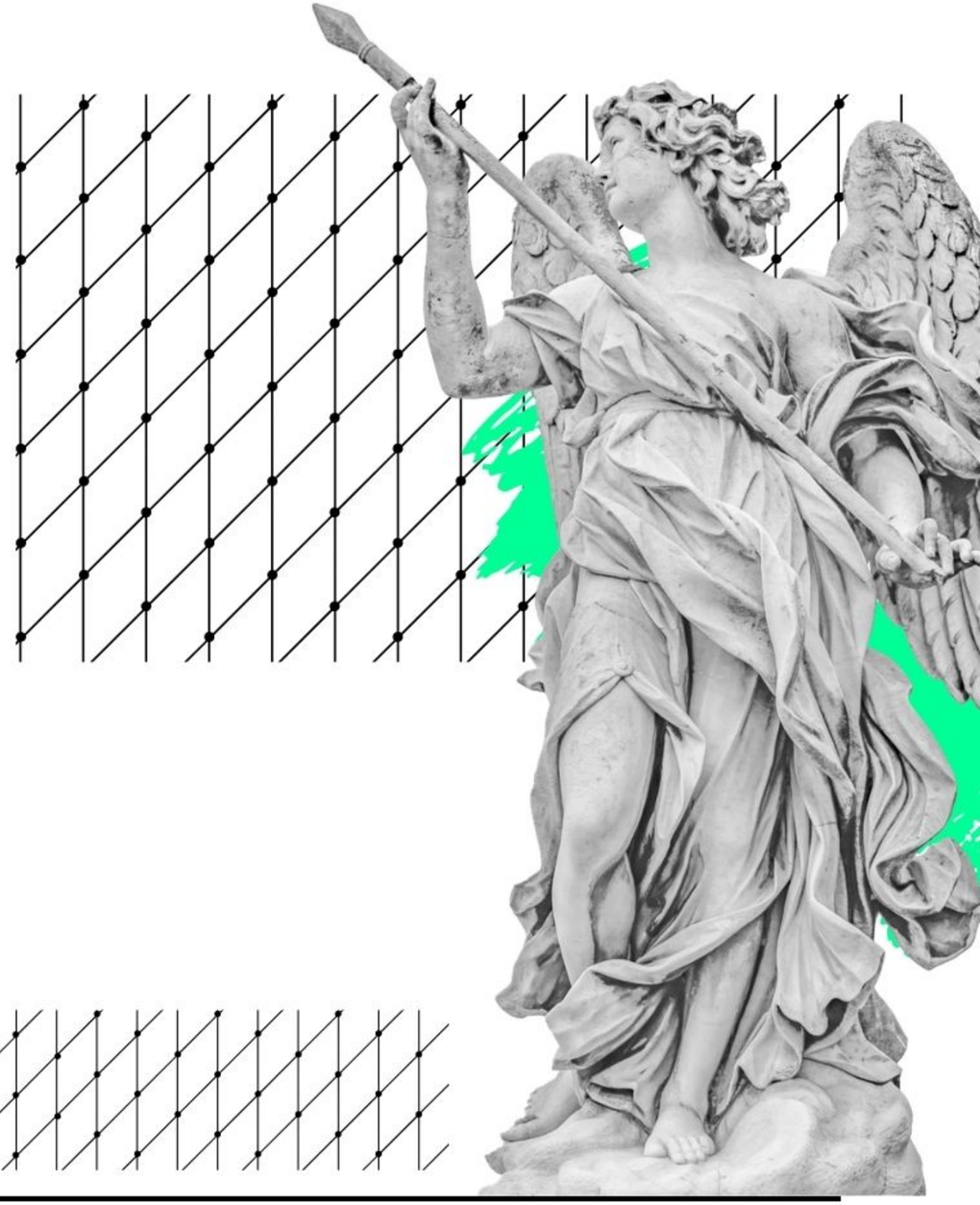


PROCHAINES FONCTIONNALITÉS

Notifications push en temps réel & receipts	V1.1
Cartes virtuelles & cashback étudiant	V2.0
Split payment & cagnottes groupées	V2.0
Partenariats bancaires externes (agrégation DSP2)	V2.0
Expansion multi-campus (15 campus EU)	V3.0
Dashboard analytics avancé (BI admin)	V3.0

KPIS DE SUCCÈS

Utilisateurs actifs / mois	500 An 1 · 1 800 An 2
Taux de détection fraude	> 95 %
Temps de réponse API (p95)	< 200 ms
Disponibilité plateforme	99,9 % SLA
Satisfaction client (NPS)	> 60
Point d'équilibre financier	Mois 17



MERCI

EPIPAY.APP